



From Payloads to People: The Other Half of the Job

Dumisani Masimini | Penetration
Tester

Why this talk?

- Pentesting isn't just about breaking things
- Real impact happens *after* the exploit
- Communication = your most underrated tool

For testers, developers, and the security-curious alike.

What We're Covering Today

- 01 Who I am — and why this matters
- 02 The payloads side: what we do technically
- 03 The people side: reports, debriefs, relationships
- 04 Translating tech into business language
- 05 Running effective debriefs
- 06 Soft skills that set you apart
- 07 Real lessons — the hard way
- 08 Practical takeaways you can use today





Who Am I?

5+

years in pentesting

100+

client engagements

2

BSides talks

Penetration Tester @ Pentest People

I started in security because I loved breaking things. Over time I learned that making things better requires something the courses don't teach: how to communicate what you found.

"The best pentest in the world is worthless if nobody acts on the findings."



Let's Check In

Quick show of hands...

- 🖐️ Who here has written a pentest report?
- 🖐️ Who has sat on a client debrief call?
- 🖐️ Who has had a client not act on findings?
- 🖐️ Who has ever struggled to explain a vulnerability in plain English?

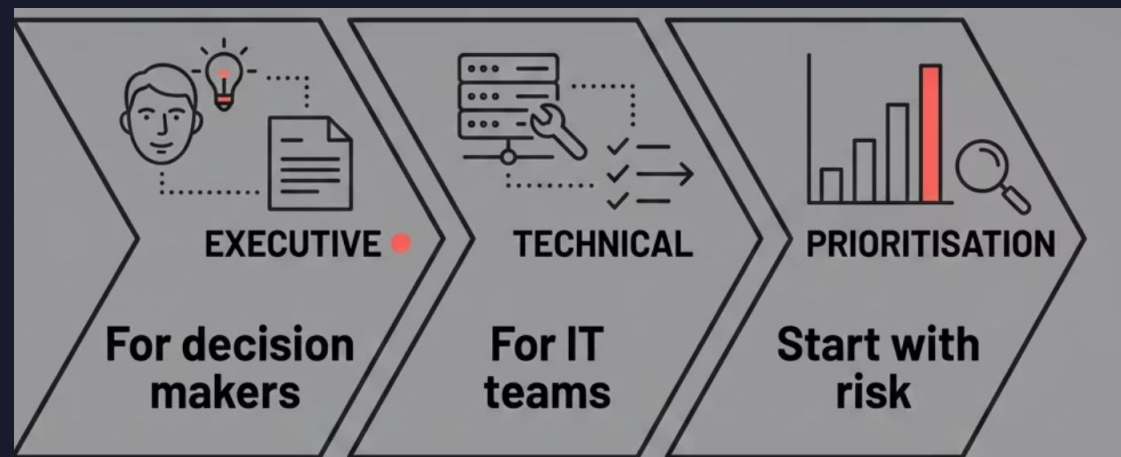
You're not alone. This is the talk I needed when I was starting out.

- # The Payloads Side
- Clients expect technical wins.
 - But this is only half the job.
- ```
[HTTP] Sending NTLM authentication request to 10.10.10.69
[HTTP] Host : kali
[WebDAV] NTLMv2 Client : 10.10.10.69
[WebDAV] NTLMv2 Username : BRAVOTEAM\SRV01$
[WebDAV] NTLMv2 Hash : SRV01$::BRAVOTEAM:6bf888e994dcaae4:4A4E96A8A2F3DAF49130964A23E184
5A0039005400370037003400420044000400140057004900330043002E004C004F00430041004C00030034005700
043002E004C004F00430041004C00080030003000000000000000000000004000002F81F87F38E689D02C27B48
00690000000000000000000000
[*] [MDNS] Poisoned answer sent to 10.10.10.69 for name kali.local
[*] [LLMNR] Poisoned answer sent to 10.10.10.69 for name kali
[HTTP] Sending NTLM authentication request to 10.10.10.69
[HTTP] Host : kali
[WebDAV] NTLMv2 Client : 10.10.10.69
Server started, waiting for connections
*] SMBD-Thread-4: Connection from BRAVOTEAM/SPENSER@10.10.10.69 controlled
*] Authenticating against smb://10.10.10.55 as BRAVOTEAM/SPENSER SUCCEED
*] SMBD-Thread-4: Connection from BRAVOTEAM/SPENSER@10.10.10.69 controlled
-] Authenticating against smb://10.10.10.69 as BRAVOTEAM/SPENSER FAILED
*] Service RemoteRegistry is in stopped state
*] Starting service RemoteRegistry
*] Target system bootKey: 0x1acf7339e7d4eca55681fa9795657e99
*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
administrator:500:aad3b435b51404eeaad3b435b51404ee:59fc0f884922b4ce37605113
uest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0
efaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d
DAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:cd06b02e9a5d525fd9e
*] Done dumping SAM hashes for host: 10.10.10.55
*] Stopping service RemoteRegistry
```

```
[HTTP] Sending NTLM authentication request to 10.10.10.69
[HTTP] Host : kali
[WebDAV] NTLMv2 Client : 10.10.10.69
[WebDAV] NTLMv2 Username : BRAVOTEAM\SRV01$
[WebDAV] NTLMv2 Hash : SRV01$::BRAVOTEAM:6bf888e994dcaae4:4A4E96A8A2F3DAF49130964A23E184
5A0039005400370037003400420044000400140057004900330043002E004C004F00430041004C00030034005700
043002E004C004F00430041004C00080030003000000000000000000000000004000002F81F87F38E689D02C27B48
006900000000000000000000
[*] [MDNS] Poisoned answer sent to 10.10.10.69 for name kali.local
[*] [LLMNR] Poisoned answer sent to 10.10.10.69 for name kali
[HTTP] Sending NTLM authentication request to 10.10.10.69
[HTTP] Host : kali
[WebDAV] NTLMv2 Client : 10.10.10.69
Server started, waiting for connections
D-Thread-4: Connection from BRAVOTEAM/SPENSER@10.10.10.69 controlled
enticating against smb://10.10.10.55 as BRAVOTEAM/SPENSER SUCCEED
D-Thread-4: Connection from BRAVOTEAM/SPENSER@10.10.10.69 controlled
enticating against smb://10.10.10.69 as BRAVOTEAM/SPENSER FAILED
vice RemoteRegistry is in stopped state
rting service RemoteRegistry
get system bootKey: 0x1acf7339e7d4eca55681fa9795f657e99
ping local SAM hashes (uid:rid:lmhash:nthash)
rator:500:aad3b435b51404eeaad3b435b51404ee:59fc0f884922b4ce3760511
01:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c
Account:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59
ityAccount:504:aad3b435b51404eeaad3b435b51404ee:cd06b02e9a5d525fd9
e dumping SAM hashes for host: 10.10.10.55
pping service RemoteRegistry
```

# The People Side

- Reports, debriefs, and relationships.
- Clients care about risk, not CVEs.
- You are the bridge between tech & action.



A stylized illustration of a man with dark skin, short black hair, and a friendly expression. He is wearing a dark blue suit jacket over a white shirt and a dark tie. The background behind him is a warm, orange-toned office interior with large windows and desks.

# What Clients Actually Want to Know

Clients aren't thinking about CVSS scores. They're thinking about their **business.**

**“How bad is this, really?”**

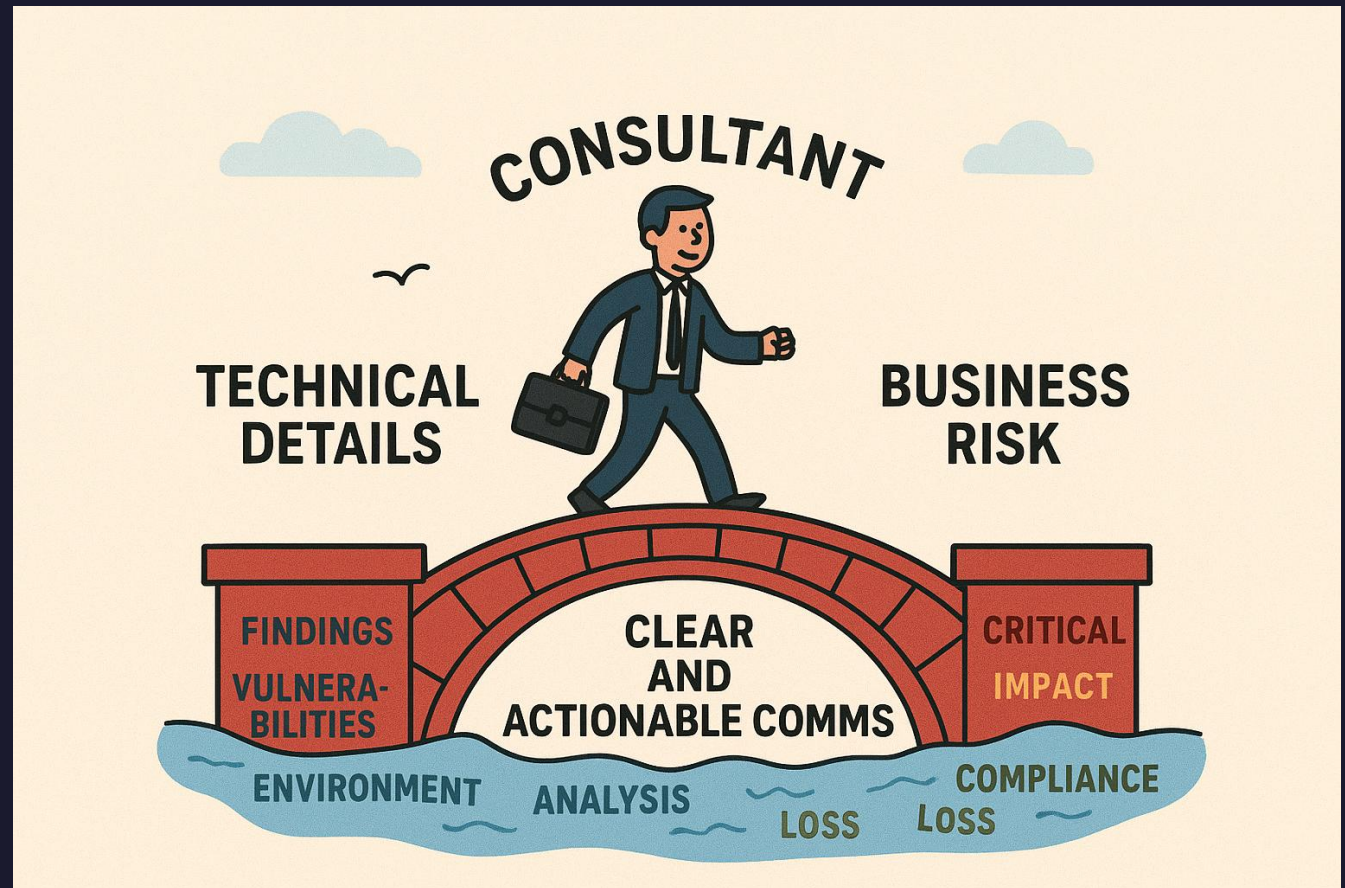
**“Are we exposed right now?”**

**“How does this affect our customers?”**

**“What do we do first?”**

*These are the questions you must be prepared to answer — in plain, confident language — before you open the report.*

# Tools of the Trade



# Report Writing: Before vs After

## ✗ BEFORE (the bad version)

Title: CVE-2021-44228 — Apache Log4j RCE

CVSS Score: 10.0 (Critical)

Description: An unauthenticated remote code execution vulnerability exists in Apache Log4j2 versions 2.0-beta9 through 2.14.1 via the `{jndi}` lookup feature. A remote attacker can exploit this to execute arbitrary code via a specially crafted string.

Remediation: Upgrade to Apache Log4j 2.15.0 or later. Apply vendor patch. Review JNDI configuration.

## ✓ AFTER (the good version)

An attacker with no credentials can take complete control of your servers remotely.

What this means for you: Anyone on the internet could access, steal, or destroy your customer data and internal systems — with no warning and no trace.

We found this on your public-facing logging system. It is actively exploited in the wild right now.

What to do: Your IT team needs to apply a single update (Log4j 2.15.0) this week. We can walk them through it. This is your highest priority fix.

A stylized illustration of a man with dark skin, short black hair, and a friendly expression. He is wearing a dark blue suit jacket over a white shirt and a dark tie. The background behind him is a warm, orange-toned office interior with large windows and desks.

# How to Speak Client

---

*Same finding. Two different languages.*

**✗ Jargon version:**

*“We identified an unauthenticated SQL injection vulnerability with a CVSS score of 9.8 in the login endpoint, enabling full database compromise.”*

**✓ Plain English version:**

*“We found a way to access your entire customer database without a password — using just a web browser. Anyone who found this could read, steal or delete every record you hold.”*

*The second version gets fixed. The first gets filed away.*

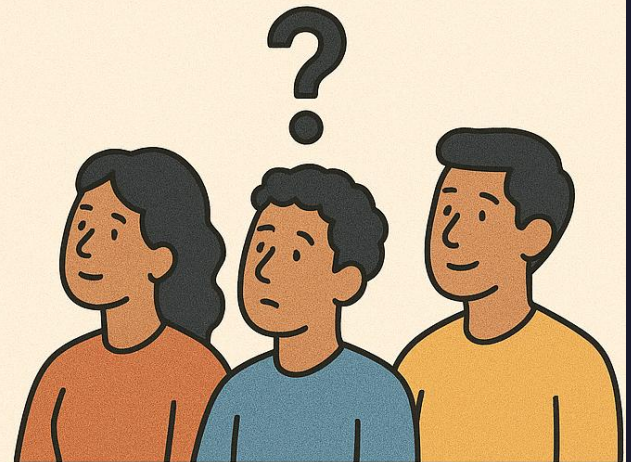
# Running Effective Debriefs

- Don't just read the report — tell the story.
- Handle tricky questions with clarity.
- Explain risk without jargon.

## STORYTELLING, NOT JUST READING



## HANDLING TRICKY QUESTIONS



## EXPLAINING RISK WITHOUT JARGON

# Soft Skills That Set You Apart



An illustration of a man with dark skin and short black hair, wearing a dark blue suit, white shirt, and dark tie. He is smiling slightly and looking towards the right. The background behind him is a warm, orange-toned office interior with large windows and desks.

# Mistakes That Kill Your Impact

---

## 01 Jargon overload

CVEs and CVSS scores mean nothing to a CFO.

## 02 No executive summary

Decision makers stop reading after page 1.

## 03 Findings not prioritised

If everything is critical, nothing is critical.

## 04 Reading the report aloud

A debrief is a story, not a recital.

## 05 Getting defensive

Pushback is fear — meet it with calm, not ego.

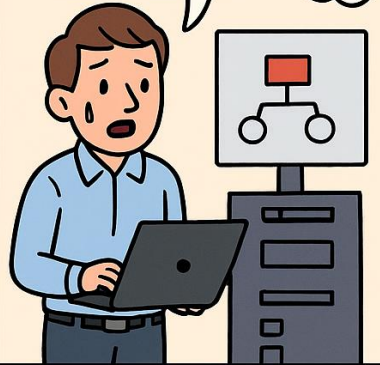
# What I've Learned (the Hard Way)

- Stories from real engagements.
- What worked — and what didn't.
- Growth moments as a consultant.

## WHAT I'VE LEARNED (the HARD WAY

### BREAKING THE NETWORK

Ran nmap without permission...



### KEEPING CALM

Acknowledge the mistake.  
Stay calm.



### GROWTH MOMENTS

It's about finding solutions, not blame.



# Practical Takeaways

Five things you can apply starting with your next engagement — whether you're writing your first report or your hundredth.

1

## Connect Findings to Client Value

Every vulnerability should answer: *"So what does this mean for the business?"*

2

## Write for All Audiences

Executive summary up top, technical depth below. Serve both readers in a single document.

3

## Lead Debriefs with Confidence

Tell the story. Bring empathy. Make it a conversation, not a reading.

4

## Lead with Business Impact

Clients remember risk in dollars and reputation — not CVE IDs.

5

## Build Soft Skills Deliberately

Train communication and EQ with the same discipline you bring to a CTF.

# The other half of the job starts now.

Technical excellence gets you in the room. **Communication** is what keeps you there — and what makes clients trust you with their most critical risks.



Find the vulnerability



Write the report



Tell the story



Build the relationship



# What Next? Resources for You

---

## Take these away tonight:

-  **Read:** "Tribe of Hackers" — communication lessons from practitioners, not just technical war stories.
-  **Read:** "The Pyramid Principle" by Barbara Minto — the best book on structured communication ever written.
-  **Listen:** Darknet Diaries podcast — hear how real incidents are explained to non-technical audiences.
-  **Practice:** After your next finding, write two versions: one for an engineer, one for a CEO. Doing CTFs, do a writeout on the next box.
-  **Connect:** Scan the QR code on the final slide.

# Thank You



**Dumisani Masimini**  
Penetration Tester



*Questions, connections, and conversations welcome.*

Q&A